Análise qualitativa e quantitativa na classificação de ameaças através do desenvolvimento de um software para detecção de phishing em e-mails corporativos

Karyna da Costa Pirola, Matheus Dias Yamasato, Nicolas Kaue de Souza Rufino, Suhelen Gonçalves Marques, Thayssa Afonso Souza[1]

Orientador: Professor Me. Gilberto Alves Pereira

Faculdade Impacta
São Paulo, SP, Brasil
Junho de 2026

RESUMO

Com o avanço da inteligência artificial, e-mails maliciosos tornaram-se cada vez mais difíceis de serem identificados pela análise humana. Diante disso, este projeto tem como objetivo desenvolver e avaliar, quantitativamente e qualitativamente, um software automatizado de detecção de phishing em ambientes corporativos. Integrado com a caixa de entrada do servidor de e-mail, o sistema analisa características específicas, como a presença de links suspeitos, linguagem urgente, anexos maliciosos e remetentes desconhecidos. De acordo com as regras e padrões definidos pelas bases públicas Sting9 Research Initiative e Kaggle datasets, o e-mail é classificado em uma das três categorias: seguro, suspeito ou phishing. Adicionalmente, a ferramenta produz alertas em tempo real, relatórios sobre os e-mails categorizados e dashboards interativos com Power BI. A validação ocorrerá em parceria com a empresa Health2B Hospitalar Ltda., onde a pesquisa qualitativa definiu os requisitos funcionais. O desempenho técnico será avaliado pela acurácia, precisão, recall e F1-score.

Palavras-chave: Phishing. Segurança da informação. Classificação de e-mails. Detecção de ameaças. Análise de dados. Fator Humano. Aprendizado de Máquina.

ABSTRACT

As artificial intelligence advances, malicious emails have become increasingly difficult to identify through human analysis. In this context, this project aims to develop and evaluate, both quantitatively and qualitatively, an automated phishing detection software for corporate environments. Integrated with the email server inbox, the system analyzes specific characteristics such as the presence of suspicious links, urgent language, malicious attachments, and unknown senders. Based on rules and patterns defined by the public datasets Sting9 Research Initiative and Kaggle datasets, each email is classified into one of three categories: safe, suspicious, or phishing. Additionally, the tool generates real-time alerts, reports on categorized emails, and interactive dashboards using Power BI. Validation will be carried out in partnership with Health2B Hospitalar Ltda., where the qualitative research was conducted to define the functional requirements. Technical performance will be assessed by accuracy, precision, recall, and F-1 score metrics.

Key words: Phishing. Information security. Email classification. Threat detection. Data analysis. Human Factor. Machine Learning.

[1] Os autores podem ser contatados respectivamente pelos seus correios eletrônicos: karyna.pirola@aluno.impacta.edu.br, matheus.yamasato@aluno.impacta.edu.br, nicolas.rufino@aluno.impacta.edu.br, suhelen.marques@aluno.impacta.edu.br, thayssa.souza@aluno.impacta.edu.br

1 INTRODUÇÃO

De acordo com o guia da ABIN (2022), a engenharia social pode ser caracterizada como um método usado para enganar, manipular e/ou explorar a confiança das pessoas, sendo realizado através de ataques sem violência física, com o objetivo de que a vítima realize ações prejudiciais a si mesma de forma voluntária. O *phishing* tornou-se uma das ameaças atuais mais críticas à segurança cibernética por meio dessas táticas. Segundo a IBM ([s.d.]), essa prática consiste no envio de comunicações fraudulentas que imitam fontes confiáveis para induzir o usuário a revelar dados sensíveis, como senhas e informações financeiras, ou a instalar softwares maliciosos, como o *ransomware*, que comprometem a integridade dos sistemas organizacionais e pessoais.

A eficácia dessas táticas é alcançada por meio da manipulação de gatilhos psicológicos, como o senso de urgência e o medo, que muitas vezes se sobrepõem às barreiras técnicas de segurança convencionais, tornando o erro humano o principal vetor da invasão. Atualmente, o cenário de riscos é agravado pela integração da inteligência artificial generativa, que permite aos criminosos criar mensagens altamente sofisticadas e desprovidas de erros gramaticais, dificultando a detecção por parte dos usuários (IBM, [s.d.]). Publicações recentes apontam que modelos de linguagem de grande escala (LLMs), favoreceram a automatização e personalização de alto nível em campanhas de *phishing,* alcançando desempenho semelhante aos produzidos por profissionais da área (Heiding *et al*., 2024).

Além disso, o impacto do *phishing* vai muito além do roubo de credenciais. De acordo com o relatório *IBM Cost of a Data Breach* (2025), o custo médio global de uma violação de dados alcançou US$4,4 milhões, evidenciando a gravidade financeira associada a esse tipo de incidente. Ademais, ataques dessa natureza podem gerar consequências significativas, como comprometimento de dados sensíveis e de propriedade intelectual, interrupção de operações e danos à reputação das organizações.

Considerando esse cenário, abordagens fundamentadas em treinamentos e conscientização tendem a apresentar eficácia limitada, considerando que usuários bem treinados podem ser vítimas de técnicas complexas e sofisticadas. (Alkhalil *et al*., 2021). Esse fator indica a necessidade de estratégias complementares aos treinamentos, que se baseiam em controles técnicos, monitoramento contínuo e mecanismos automatizados de detecção, reduzindo a dependência exclusiva do usuário.

Nesse contexto, instituições e indivíduos podem se valer da cibersegurança para a prevenção desse tipo de golpe. Cibersegurança é compreendida como um conjunto estratégico de medidas, tecnologias e diretrizes que visam proteger a infraestrutura digital contra ataques e invasões. Conforme os preceitos de segurança da informação, esse campo busca preservar três pilares fundamentais: a confidencialidade, a integridade e a disponibilidade dos dados (Oliveira; Kovalscki, 2025).

Figura 1– A base da cibersegurança e os impactos do *phishing* em cada vértice.

Commented [1]: deixar apenas um linha em branco antes e depois de todos os titulos

Commented [2]: retirar as linhas em branco entre parágrafos - fazer isso para todo o texto



Fonte: Natsar Cyber Insights - Substack (2024).

Commented [3]: USAR TAM 10 NAS FONTES DE FIGURAS E QUADROS

A confidencialidade baseia-se no princípio do privilégio mínimo para impedir o acesso não autorizado a dados sensíveis, mitigando o risco corporativo de divulgação indesejada. A integridade consiste em garantir que as informações permaneçam exatas, completas e confiáveis, reduzindo o risco de alteração ou modificação não autorizada dos dados. Disponibilidade consiste em garantir que sistemas e dados permaneçam acessíveis e utilizáveis pelos usuários sempre que necessário, evitando o risco corporativo de interrupção operacional. (Moulin, 2025) Ao estabelecer barreiras contra o uso indevido de sistemas, a cibersegurança garante a continuidade das operações em um cenário de ameaças complexas.

No que diz respeito ao combate ao *phishing*, o desenvolvimento de softwares voltados à identificação de padrões de ataque é essencial, pois essas ferramentas conseguem analisar grandes volumes de dados e reconhecer anomalias que indicam fraudes. A automação defensiva serve como um filtro técnico rigoroso, permitindo que as tentativas de golpe sejam barradas antes que o usuário precise tomar uma decisão de risco. Complementando essa barreira tecnológica, o treinamento e a conscientização dos indivíduos são pilares indispensáveis (Oliveira; Kovalscki, 2025). Como o *phishing* explora vulnerabilidades comportamentais, a educação digital transforma o usuário em uma camada de defesa ativa. Com base nisso, a eficácia da proteção reside na união entre o suporte técnico (como softwares para detecção de padrões maliciosos) e o fator humano, reduzindo drasticamente as chances de sucesso de invasores.

A partir disso, este estudo orienta-se pela seguinte questão de pesquisa: em que medida um sistema automatizado de detecção de *phishing* auxilia na mitigação de ataques em ambientes corporativos, reduzindo a dependência exclusiva da análise humana, e qual é a percepção dos usuários sobre a utilização dessa ferramenta?

Diante do avanço de campanhas cada vez mais sofisticadas, impulsionadas pelo uso intensivo de Inteligência Artificial, o desenvolvimento e a análise de soluções automatizadas capazes de identificar ameaças com maior precisão e velocidade são justificados. Contudo, considerando que o fator humano permanece decisivo no processo de interação com mensagens suspeitas, também é pertinente avaliar a percepção dos usuários quanto à sua aplicabilidade, confiabilidade e contribuição para a tomada de decisão no ambiente corporativo.

Nesse sentido, este artigo propõe o desenvolvimento de um software baseado nos algoritmos Naive Bayes e Random Forest para automatizar a classificação de e-mails por meio de técnicas de *machine learning* em um ambiente corporativo real. Além disso, o estudo busca

avaliar qualitativamente a percepção dos usuários sobre a aplicabilidade e a usabilidade da solução no contexto organizacional, considerando aspectos como confiança, facilidade de adoção e impacto no cotidiano de trabalho.

2 **METODOLOGIA**

Trata-se de uma pesquisa aplicada, com objetivos descritivos e abordagem híbrida, combinando métodos quantitativos e qualitativos, a fim de compreender tanto o desempenho técnico de um sistema automatizado de detecção de *phishing* quanto a percepção dos usuários sobre sua aplicabilidade no ambiente corporativo. Segundo Gil (2002), a pesquisa aplicada tem como objetivo gerar conhecimento orientado à solução de problemas específicos, ao passo que a abordagem descritiva tem como objetivo registrar e analisar fenômenos sem interferência do pesquisador. A integração dessas perspectivas permite uma análise mais abrangente do problema, contemplando aspectos tecnológicos e humanos envolvidos no processo de identificação de e-mails maliciosos (Minayo, 2014).

A pesquisa é estruturada em três etapas principais: revisão bibliográfica, investigação qualitativa exploratória e análise quantitativa de desempenho do software, concentrada na avaliação dos algoritmos Naive Bayes e Random Forest aplicados à classificação de e-mails.

2.1 REVISÃO BIBLIOGRÁFICA

O levantamento bibliográfico foi realizado em diversas bases científicas como Google Acadêmico, Scielo e ACM Digital Library. A pesquisa foi realizada com as seguintes palavras-chave: *phishing*, *machine learning* para detecção de *phishing*, prevenção ao *phishing*, segurança da informação, classificação de texto, processamento de linguagem natural e cibersegurança corporativa. A busca foi restrita a trabalhos publicados a partir de 2020, analisando artigos escritos em português e inglês. Segundo Gil (2002), a delimitação temporal na revisão bibliográfica contribui para que as referências selecionadas reflitam os avanços mais recentes da área.

2.2 CLIENTE

A validação do sistema será realizada com a empresa Health2B Hospitalar Ltda., consultoria especializada em gestão de saúde corporativa, com sede em São Bernardo do Campo/SP. A empresa trabalha diretamente com informações pessoais, dados sensíveis de saúde e informações financeiras de seus clientes.

A parceria com a Health2B permitirá o acesso a um ambiente corporativo real para a identificação das necessidades organizacionais da empresa e do histórico de registros de *phishing*, a realização de entrevistas com os colaboradores e o teste do software desenvolvido

com e-mails reais recebidos pela organização. A aplicação do estudo respeitará os protocolos éticos e de privacidade de dados em conformidade com a Lei Geral de Proteção de Dados Pessoais, conhecida como LGPD (Brasil, 2018).

2.3 PESQUISA QUALITATIVA EXPLORATÓRIA

Com o objetivo de compreender como é realizada a identificação e o tratamento de e-mails maliciosos no ambiente corporativo e estabelecer os requisitos funcionais do sistema, será compartilhado um formulário on-line com os colaboradores das áreas de vendas, operações e de engenharia de dados, abordando os seguintes temas:

a) Detecção e frequência de e-mails suspeitos recebidos;
b) Fluxo atual de tratamento de e-mails maliciosos;
c) Requisitos funcionais e integração com o correio eletrônico utilizado na empresa;
d) Expectativas em relação às classificações dos e-mails pelo sistema;
e) Relatórios e rastreabilidade de incidentes.

Serão realizadas perguntas direcionadas para compreender como os colaboradores lidam com *phishing*, quais recursos consideram fundamentais que tenham no software de classificação de e-mails e as informações necessárias para compor o relatório. Conforme Minayo (2014), a pesquisa qualitativa de caráter exploratório permite compreender a experiência e a perspectiva dos entrevistados, sendo adequada para identificar como os colaboradores percebem e lidam com situações no ambiente corporativo, permitindo que os entrevistados respondessem livremente sobre suas experiências, dificuldades e expectativas. Segundo Gil (2002), o questionário é um instrumento de coleta de dados que possibilita um número expressivo de respostas e garante o anonimato dos entrevistados, favorecendo a espontaneidade dos participantes. As respostas coletadas serviram de base para determinar as funcionalidades do sistema. O formulário aplicado encontra-se no Apêndice A deste trabalho.

2.4 DESENVOLVIMENTO DO SISTEMA

O sistema será desenvolvido com objetivo de detectar e classificar e-mails em ambiente corporativo de forma automatizada.

2.4.1 Fluxo de funcionamento

O fluxo de funcionamento seguirá as etapas abaixo:

1) Quando um e-mail chegar a caixa de entrada, será realizada uma triagem automatizada sobre o conteúdo via integração com APIs;
2) Análise pelo modelo de classificação que verifica características indicativas de *phishing*;
3) Classificação do e-mail em uma das três categorias: seguro, suspeito ou *phishing*.
4) Exibição de alerta em tempo real ao usuário e aplicação da etiqueta de categorização no e-mail.

O sistema também inclui a geração de relatórios sobre a frequência de e-mails maliciosos recebidos, identificação de padrões e um dashboard interativo desenvolvido em Power BI para análise e visualização dos dados.

2.4.2 Tecnologias utilizadas

No Quadro 1 estão descritas as tecnologias que serão utilizadas para desenvolver o sistema e suas respectivas finalidades:

Quadro 1 – Tecnologias utilizadas

Tecnologia	Finalidade	Camada
C#	Integração com e-mail, autenticação e orquestração	Backend
Python	Microsserviço de classificação, responsável por executar os algoritmos de machine learning	Machine Learning
TF-IDF	Transforma o texto dos e-mails em dados numéricos, identificando palavras com frequência suspeita	Machine Learning
Naive Bayes	Algoritmo que calcula a probabilidade de um e-mail ser phishing de acordo com as palavras identificadas	Machine Learning
Random Forest	Algoritmo que combina múltiplas árvores de decisão para uma classificação robusta	Machine Learning
React	Interface do usuário e alertas em tempo real	Frontend
Power BI	Dashboard interativo e análise de padrões	Relatórios

Fonte: Elaborado pelos autores (2026).

Commented [4]: QUAL VERSÃO?

2.4.3 Treinamento e validação do modelo de classificação

A base de dados que será utilizada para treinamento e validação do modelo de classificação é composta por duas fontes complementares:

1) API Sting9 Research Initiative: repositório com e-mails e SMS reais de *phishing* classificados por tipo de ataque (*spear phishing*, *whaling, smishing*, entre outros) e nível de risco.
2) Phishing Email Dataset (Kaggle): conjunto de dados públicos utilizados em pesquisas de segurança da informação, contendo e-mails categorizados como legítimos e maliciosos, sendo uma fonte para o treinamento supervisionado de modelos de *machine learning*.

O conjunto de dados será dividido na proporção de 80% para treinamento e 20% para teste, garantindo que o modelo seja avaliado em amostras não utilizadas durante o aprendizado. Para assegurar a robustez dos resultados e reduzir o risco de *overfitting*, será aplicada a técnica de validação cruzada k-fold (k=10), na qual o conjunto de treinamento é subdividido em 10 partes iguais, utilizadas alternadamente para treino e validação (Géron, 2019). O pré-processamento dos dados irá incluir a remoção de duplicatas, normalização do texto, eliminação de *stopwords* e a vetorização por meio do TF-IDF. Os parâmetros dos algoritmos serão mantidos em suas configurações padrão da biblioteca scikit-learn, garantindo a reprodutibilidade dos experimentos.

2.5 ANÁLISE QUANTITATIVA

Para mensurar o desempenho do sistema desenvolvido, serão utilizados e-mails reais recebidos pelos colaboradores, respeitando os princípios estabelecidos pela LGPD, lei nº 13.709/2018 (Brasil, 2018). O software irá classificar os e-mails e sua atuação será avaliada pelas métricas descritas no Quadro 2:

Quadro 2 – Métricas de avaliação do modelo de classificação

Métrica	**Descrição**
Acurácia	Proporção de e-mails classificados corretamente sobre a quantidade total analisada
Precisão	Dos e-mails classificados como phishing, quantos realmente eram
Recall	De todos os e-mails que eram phishing, quantos o sistema conseguiu detectar corretamente
F1-score	Métrica entre precisão e recall, indicador balanceado do desempenho geral do software

Fonte: Adaptado de Mariano (2021)

Commented [5]: por que foram escolhidas essas métricas?

Commented [6]: por que foram escolhidas essas métricas?

Commented [7]: por que foram escolhidas essas métricas?

Commented [8]: por que foram escolhidas essas métricas?

Commented [9]: por que foram escolhidas essas métricas?

O desempenho do sistema será avaliado considerando a atuação combinada dos algoritmos Naive Bayes e Random Forest, que irão atuar em conjunto para classificar os e-mails, tornando a detecção mais eficiente e precisa.

2.6 ANÁLISE QUALITATIVA

Após a implementação do software na Health2B Hospitalar Ltda., será compartilhado um formulário on-line de caráter dissertativo aos colaboradores que participaram da etapa de levantamento de requisitos visando coletar suas percepções sobre o uso da ferramenta no dia a dia. Conforme Minayo (2014), a análise qualitativa permite compreender a experiência dos colaboradores mais profundamente, captando percepções e impressões que não seriam possíveis de mensurar apenas por métricas quantitativas.

As questões foram elaboradas de forma aberta para que os entrevistados possam responder livremente sobre os seguintes tópicos abordados:

a) Clareza dos alertas exibidos pelo sistema;
b) Confiança nas classificações realizadas;
c) Pontos positivos sobre o software;
d) Limitações identificadas;
e) Sugestões de melhorias.

O formulário que será aplicado encontra-se no Apêndice B deste artigo.

2.7 LIMITAÇÕES DA PESQUISA

Esta pesquisa apresenta limitações que devem ser levadas em conta ao analisar os resultados. Na etapa qualitativa, as respostas coletadas via formulário on-line refletem a visão individual de cada colaborador, o que naturalmente introduz subjetividade nas análises. Como a pesquisa foi realizada com um grupo restrito de colaboradores da Health2B, os resultados não necessariamente se aplicam a outros ambientes corporativos.

Em relação aos dados utilizados no treinamento do modelo, os *datasets* públicos Sting9 e Kaggle, apesar de amplamente utilizados em pesquisas da área, podem não capturar todos os padrões de *phishing* presentes no cotidiano de uma empresa especializada no setor de saúde. E-mails maliciosos podem variar conforme o setor, o porte da empresa e o perfil dos colaboradores, sendo necessário ajustar o software para se adaptar melhor à realidade de cada organização.

Por fim, o cenário de ameaças digitais muda rapidamente, evoluindo de forma contínua, o que significa que um modelo treinado hoje pode perder a eficácia com o tempo caso não seja atualizado regularmente.

3 **FUNDAMENTAÇÃO TEÓRICA**

Para entender por que sistemas automatizados de detecção de phishing são necessários, é preciso olhar para o problema de forma mais ampla. Ou seja, não basta saber que os ataques existem, é preciso entender como eles exploram a confiança das pessoas, o motivo das defesas tradicionais já não estarem dando conta e de que forma a tecnologia pode ajudar a preencher

essa lacuna. Por isso, esta seção percorre três eixos: a engenharia social e o phishing como ameaça concreta, a segurança da informação no contexto corporativo e, por fim, o papel do aprendizado de máquina e do Processamento de Linguagem Natural (PLN) na identificação automatizada de e-mails maliciosos. O combate às ameaças digitais modernas exige uma abordagem que una a compreensão do comportamento humano ao refinamento dos algoritmos de proteção.

3.1 ENGENHARIA SOCIAL E O PHISHING COMO AMEAÇA CIBERNÉTICA

A engenharia social representa uma das formas mais antigas e eficazes de manipulação humana aplicadas ao contexto digital. Diferentemente de ataques que exploram vulnerabilidades técnicas em sistemas, essa abordagem tem como alvo o comportamento humano, explorando traços psicológicos como confiança, medo, curiosidade e senso de urgência para induzir a vítima a agir de forma prejudicial a si mesma (Abin, 2022). Essa mudança de alvo, do sistema para o indivíduo, representa um problema estrutural para as defesas convencionais: firewalls e antivírus protegem sistemas, mas não decisões humanas.

Dentro desse espectro, o *phishing* se consolidou como uma das manifestações mais dominantes e prejudiciais da engenharia social no ambiente digital. O termo, derivado da palavra em inglês *fishing* (pescar), faz alusão à ideia de "lançar iscas" para atrair vítimas. Na prática, consiste no envio de comunicações fraudulentas, geralmente por e-mail, que imitam fontes confiáveis, como bancos, fornecedores ou colegas de trabalho, com o objetivo de induzir o destinatário a revelar informações sensíveis ou a executar ações que comprometam a segurança dos sistemas (IBM, [s.d.]).

O que torna esse cenário preocupante é a trajetória recente da sofisticação dos ataques. Se antes erros gramaticais e formatação errada serviam como sinais de alerta, a integração da inteligência artificial generativa eliminou esses indicadores: criminosos passaram a criar mensagens corretas, adaptadas ao perfil da vítima e com contexto corporativo verossímil (IBM, [s.d.]). Isso expõe uma limitação crítica das estratégias de defesa baseadas exclusivamente em conscientização do usuário, pois, por mais treinado que esteja, o colaborador enfrenta ataques criados para superar sua avaliação. Essa constatação é o ponto de partida para a discussão que se seguirá nas próximas seções: se o vetor humano é estruturalmente vulnerável, a resposta eficaz precisa residir na automação inteligente da detecção.

3.2 SEGURANÇA DA INFORMAÇÃO E CIBERSEGURANÇA CORPORATIVA

A segurança da informação pode ser compreendida como o conjunto de práticas, políticas e tecnologias que visam proteger os dados contra acessos não autorizados, alterações indevidas e indisponibilidade. Esse campo é estruturado em torno de três pilares fundamentais, conhecidos como tríade CIA: *Confidentiality* (confidencialidade), *Integrity* (integridade) e *Availability* (disponibilidade) (Oliveira; Kovalscki, 2025).

A confidencialidade garante que as informações sejam acessadas apenas por pessoas devidamente autorizadas. A integridade assegura que os dados não sejam alterados de forma não autorizada, preservando sua confiabilidade. Já a disponibilidade diz respeito à garantia de que as informações e os sistemas estarão acessíveis quando necessários para os usuários. Um ataque de *phishing* bem-sucedido pode comprometer simultaneamente os três pilares: ao capturar credenciais de acesso, o atacante viola a confidencialidade; ao manipular ou excluir dados, compromete a integridade; e ao instalar *ransomware*, pode tornar sistemas inteiros indisponíveis.

No contexto corporativo, esse risco ganha uma profundidade a mais. Empresas que lidam com dados sensíveis (como informações de saúde, dados financeiros e informações pessoais de clientes) não apenas enfrentam prejuízos operacionais, mas também estão sujeitas a sanções legais significativas. A LGPD, lei nº 13.709/2018, estabelece responsabilidades claras para as organizações no tratamento e na proteção de dados pessoais, tornando a adoção de medidas de segurança uma obrigação legal que impacta diretamente a sustentabilidade do negócio. Isso coloca a detecção de *phishing* em outro nível: não se trata apenas de uma questão técnica, mas de conformidade legal.

3.3 MACHINE LEARNING APLICADO À DETECÇÃO DE PHISHING

O aprendizado de máquina (*machine learning*) é um subcampo da inteligência artificial que permite que sistemas computacionais aprendam padrões a partir de dados e realizem classificações sem serem explicitamente programados para cada situação. No campo da segurança da informação, essa abordagem tornou-se relevante pelo volume crescente de mensagens que precisam ser analisadas em tempo real, volume incompatível com a triagem manual. Conforme mencionam Altwaijry *et al.* (2024), o *phishing* está entre os ataques mais perigosos enfrentados por organizações, e os modelos de *machine learning* têm se destacado por sua capacidade de processar grandes volumes de mensagens e identificar padrões indicativos de ataque, superando a rigidez dos filtros tradicionais baseados em regras estáticas ou listas negras.

A detecção de *phishing* via *machine learning* é tratada como um problema de classificação supervisionada: o modelo aprende a partir de e-mails previamente rotulados como legítimos ou maliciosos e passa a identificar padrões que distinguem as duas categorias. Alkhalil *et al.* (2021) observa que quanto mais diversificada for a base de treinamento, maior a capacidade de generalização do modelo, condição diretamente relacionada à robustez do sistema em ambientes corporativos reais, onde os ataques não seguem um padrão fixo.

A análise comparativa da literatura, contudo, revela um *trade-off* que não pode ser ignorado: diferentes algoritmos apresentam perfis de desempenho distintos, e a escolha entre eles não é trivial. Enquanto Altwaijry *et al.* (2024) registram diferenças expressivas de acurácia entre modelos testados nos mesmos *datasets*, Alkhalil *et al.* (2021) acrescenta a dimensão do custo computacional à equação. Esse conjunto de evidências indica que a escolha de um único algoritmo implica necessariamente abrir mão de alguma vantagem, o que fundamenta a estratégia adotada neste trabalho de conciliar dois algoritmos, discutida nas subseções a seguir.

3.3.1 TF-IDF (Term Frequency-Inverse Document Frequency)

Para que algoritmos de *machine learning* possam processar textos, é necessário transformá-los em representações numéricas. O TF-IDF é uma técnica amplamente utilizada para essa finalidade, atribuindo pesos às palavras de um documento com base em dois critérios: a frequência com que o termo aparece no documento em questão (*Term Frequency*) e a raridade desse termo no conjunto total de documentos (*Inverse Document Frequency*). Palavras muito comuns em todos os documentos, como artigos e preposições, recebem pesos baixos, enquanto termos mais específicos e informativos recebem pesos maiores. Conforme demonstrado por Alkhalil *et al.* (2021) em estudo comparativo de modelos de detecção de *phishing*, o TF-IDF é uma das técnicas de extração de características mais utilizadas e eficazes para a análise de conteúdo de e-mails maliciosos.

3.3.2 Algoritmo Naive Bayes

O Naive Bayes é um algoritmo de classificação probabilística baseado no Teorema de Bayes. Ele calcula a probabilidade de um documento pertencer a uma certa classe (no caso deste trabalho, a probabilidade de um e-mail ser *phishing*) com base na frequência das palavras que ele contém. Apesar da suposição simplificadora de que as variáveis são independentes entre si, o algoritmo apresenta desempenho eficaz em tarefas de classificação de texto. Altwaijry *et al*. (2024) observam que o Naive Bayes é amplamente empregado em sistemas de detecção de e-mails maliciosos, especialmente por sua eficiência computacional e desempenho satisfatório mesmo com volumes menores de dados de treinamento.

Os números reportados pela literatura, contudo, evidenciam suas limitações objetivas. Altwaijry *et al.* (2024) registraram acurácia de 87,63% para o Naive Bayes nos *datasets* avaliados, enquanto Alkhalil *et al.* (2021) identificou desempenho ainda menor, 75,72%, em seu estudo comparativo, ainda que com o menor tempo de processamento entre todos os modelos testados. Essa combinação de velocidade com acurácia moderada revela o perfil real de aplicação do algoritmo: adequado para triagem inicial em tempo real, mas insuficiente como mecanismo único de classificação em um ambiente onde o custo de um falso negativo (um e-mail de *phishing* classificado como seguro) pode resultar em um incidente de segurança real. Utilizá-lo como único filtro em um sistema corporativo seria trocar acurácia por velocidade em um contexto onde essa troca tem consequências diretas.

3.3.3 Random Forest

O Random Forest é um algoritmo de aprendizado de conjunto (*ensemble learning*) que combina múltiplas árvores de decisão para produzir um resultado de classificação mais robusto e preciso. Cada árvore é treinada com uma amostra aleatória dos dados e considera um subconjunto aleatório das variáveis a cada divisão, o que reduz o risco de *overfitting*. A decisão final é tomada por votação majoritária entre todas as árvores. Segundo Altwaijry *et al*. (2024), algoritmos de *ensemble* como o Random Forest se destacam em tarefas de detecção de *phishing* por produzirem resultados mais estáveis e generalizáveis do que classificadores individuais.

A superioridade do Random Forest em relação ao Naive Bayes é documentada de forma consistente na literatura. Altwaijry *et al.* (2024) registraram acurácia de 99,91% para o Random Forest nos mesmos *datasets* em que o Naive Bayes atingiu 87,63% — uma diferença de mais de 12 pontos percentuais. Alharbi (2025) corrobora essa avaliação, apontando o Random Forest como o algoritmo com melhor equilíbrio entre acurácia e generalização nos experimentos conduzidos. Os dois autores convergem, portanto, na conclusão de que algoritmos de *ensemble* superam classificadores individuais tanto em precisão quanto em robustez para a detecção de *phishing*.

A contrapartida é o custo computacional: o Random Forest exige mais recursos de processamento do que o Naive Bayes, o que pode ser uma limitação em ambientes com alto volume de e-mails e necessidade de resposta imediata. É precisamente esse *trade-off* que fundamenta a escolha combinada dos dois algoritmos neste trabalho: o Naive Bayes opera na triagem inicial aproveitando sua velocidade, enquanto o Random Forest atua na classificação final, compensando as fragilidades probabilísticas do primeiro e reduzindo a taxa de falsos negativos. Essa articulação não é apenas uma soma de vantagens, mas uma estratégia às limitações individuais de cada abordagem.

3.4 PROCESSAMENTO DE LINGUAGEM NATURAL (PLN)

O Processamento de Linguagem Natural (*Natural Language Processing* - NLP) é a área da inteligência artificial responsável por capacitar computadores a compreender, interpretar e manipular a linguagem humana. No contexto da análise de e-mails, o PLN oferece as ferramentas necessárias para extrair significado do texto, identificar padrões linguísticos e transformar conteúdo não estruturado em dados processáveis por algoritmos de *machine learning*.

As técnicas centrais desse processo incluem a tokenização (divisão do texto em unidades menores como palavras ou frases), a remoção de *stopwords* (eliminação de termos sem valor discriminativo, como artigos e conjunções) e o *stemming* ou lematização, que reduz palavras à sua forma base para padronizar a análise. O TF-IDF, descrito na seção anterior, atua diretamente sobre o resultado dessas técnicas.

Na detecção de *phishing*, o PLN permite identificar padrões linguísticos recorrentes em mensagens maliciosas, como a presença de linguagem imperativa e urgente, referências a penalidades ou recompensas imediatas, e solicitações de dados sensíveis. Segundo Anti-Phishing Working Group (2025), esses elementos textuais quando quantificados e combinados com outros indicadores, como a análise de URLs e metadados do remetente, formam a base para a classificação automatizada dos e-mails em sistemas de segurança corporativa.

REFERÊNCIAS

ABIN - AGÊNCIA BRASILEIRA DE INTELIGÊNCIA. **Guia para proteção de conhecimentos sensíveis: engenharia social**. Brasília: ABIN, 2022. Disponível em: cartilha-engenharia-social-guia-para-protecao-de-conhecimentos-sensiveis. Acesso em: 23 abr. 2026.

ALKHALIL, Zainab; HEWAGE, Chaminda; NAWAF, Liqaa; KHAN, Imtiaz. **Phishing attacks: a recent comprehensive study and a new anatomy. Frontiers in Computer Science**. v. 3, art. 563060, 2021. DOI: 10.3389/fcomp.2021.563060. Disponível em: https://www.frontiersin.org/journals/computer-science/articles/10.3389/fcomp.2021.563060/full. Acesso em: 15 maio 2026.

ALTWAIJRY, Najwa; AL-TURAIKI, Isra; ALOTAIBI, Reem; ALAKEEL, Fatimah. **Advancing phishing email detection: a comparative study of deep learning models**. Sensors, v.24, n.7, 2024. Disponível em: https://www.mdpi.com/1424-8220/24/7/2077. Acesso em: 18 maio 2026.

ANTI-PHISHING WORKING GROUP. **Phishing activity trends report: 4th quarter 2025**. APWG, 2025. Disponível em: https://docs.apwg.org/reports/apwg_trends_report_q4_2025.pdf. Acesso em: 15 maio 2026.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Brasília, DF: Presidência da República, 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 07 jun. 2026.

GÉRON, Aurélien. **Hands-on machine learning with Scikit-Learn, Keras, and TensorFlow**. 2. ed. Sebastopol: O'Reilly Media, 2019. Disponível em: http://14.139.161.31/OddSem-0822-1122/Hands-On_Machine_Learning_with_Scikit-Learn-Keras-and-TensorFlow-2nd-Edition-Aurelien-Geron.pdf. Acesso em: 07 jun. 2026.

GHARIBI, Wajeb. **Some recommended protection technologies for cyber crime based on social engineering techniques-phishing**. 2012. Disponível em: https://arxiv.org/pdf/1201.0949. Acesso em: 03 maio 2026.

GIL, Antonio Carlos. **Como elaborar projetos de pesquisa**. 4. ed. São Paulo: Atlas, 2002. Disponível em: https://files.cercomp.ufg.br/weby/up/150/o/Anexo_C1_como_elaborar_projeto_de_pesquisa_-_antonio_carlos_gil.pdf. Acesso em: 07 jun. 2026.

HEIDING, Fred; LERMEN, Simon; KAO, Andrew; SCHNEIER, Bruce; VISHWANATH, Arun. **Evaluating large language models' capability to launch fully automated spear phishing campaigns: validated on human subjects**. 2024. Disponível em: https://doi.org/10.48550/arXiv.2412.00586. Acesso em: 16 maio 2026.

IBM. **O que é phishing?** IBM Think, [s.d.]. Disponível em: https://www.ibm.com/br-pt/think/topics/phishing. Acesso em: 23 abr. 2026.

IBM Security. **Cost of a data breach report 2025: the AI oversight gap**. Armonk, NY: IBM Corporation, 2025. Disponível em: https://www.ibm.com/reports/data-breach. Acesso em: 15 maio 2026.

MARIANO, Diego. **Métricas de avaliação em machine learning: acurácia, sensibilidade, precisão, especificidade e F-score**. BIOINFO - Revista Brasileira de Bioinformática e Biologia Computacional, 2021. Disponível em: https://doi.org/10.51780/978-6-599-275326-15. Acesso em: 02 maio 2026.

MINAYO, Maria Cecília de Souza. **O desafio do conhecimento: pesquisa qualitativa em saúde**. 14. ed. São Paulo: Hucitec, 2014. Disponível em: https://www.huciteceditora.com.br/. Acesso em: 22 abr. 2026.

MOULIN, Josh. **Understanding the CIA triad and its role in managing cyber risks**. 2025. Disponível em: https://natsar.substack.com/p/understanding-the-cia-triad-and-its-role-in-cyber-risk. Acesso em: 28 maio 2026.

OLIVEIRA, Andrey Guedes; KOVALSCKI, Allan. **Segurança da informação e cibersegurança**. IGCP, 2025. Disponível em: https://conhecimento.igcp.org.br/wp-content/uploads/2025/08/E-BOOK-Seguranca-da-informacao.pdf. Acesso em: 23 abr. 2026.

UNIARA – CENTRO UNIVERSITÁRIO DE ARARAQUARA. **Cybersecurity: introdução à cibersegurança: proteja seus dados no mundo digital**. Araraquara: UNIARA, 2023. Disponível em: https://www.uniara.com.br/cursos/presencial/graduacao/projeto_extensao/_sistemas_de_informacao/ebooks/Ebook%20-%20Cybersecurity.pdf. Acesso em: 23 abr. 2026.

APÊNDICES

APÊNDICE A - Formulário de Levantamento de Requisitos

Pesquisa sobre o Sistema de Detecção de E-mails de Phishing
Este formulário compõe o trabalho de conclusão de curso da graduação em Sistemas de Informação pela faculdade Impacta. O objetivo é compreender como os colaboradores da Health2B Hospitalar Ltda. percebem e lidam com e-mails maliciosos e quais funcionalidades consideram essenciais em um software de detecção e classificação automatizada.
As respostas são anônimas e serão utilizadas exclusivamente para fins acadêmicos. Tempo estimado: 5 a 10 minutos.

Seção 1: Experiência com e-mails suspeitos

1. Você já recebeu algum e-mail suspeito no trabalho? Como você detectou?
2. Que tipo de e-mail malicioso é mais comum no seu dia a dia profissional? Ex.: links falsos, solicitações de senha, e-mails se passando por fornecedores, entre outros.

Seção 2: Fluxo atual de tratamento

3. O que você costuma fazer quando identifica um e-mail suspeito? Descreva o passo a passo.
4. Na sua opinião, o processo atual de lidar com e-mails maliciosos na empresa é eficiente? Por quê?

Seção 3: Expectativas sobre o sistema

5. Se o software classificasse um e-mail como suspeito ou phishing, como você gostaria de ser notificado?
6. Quais informações você considera essenciais que o sistema apresente ao classificar um e-mail como phishing? Ex.: motivo da classificação, remetente, links detectados, orientação do que fazer, entre outros.
7. Você teria confiança em um sistema automatizado para tomar decisões sobre e-mails recebidos? Justifique.

Seção 4: Relatórios e acompanhamento

8. Que tipo de informação sobre os e-mails maliciosos recebidos seria útil acompanhar ao longo do tempo? Ex.: quantidade por período, tipos de ataque, horários, remetentes frequentes, entre outros.
9. Com que frequência você utilizaria os relatórios gerados pelo sistema?

Seção 5: Opinião livre

10. Na sua opinião, o que não pode faltar em um sistema de detecção e classificação de phishing para que seja realmente útil no dia a dia? Sinta-se à vontade para compartilhar qualquer ideia ou sugestão.

APÊNDICE B - Formulário de Avaliação do Sistema

Avaliação do Sistema de Detecção de E-mails de Phishing

Este formulário tem como objetivo coletar a percepção dos colaboradores da Health2B Hospitalar Ltda. após a utilização do sistema de detecção automatizada de e-mails de phishing. **As respostas são anônimas e serão utilizadas exclusivamente para fins acadêmicos.** Tempo estimado: 5 minutos.

Seção 1: Experiência com o sistema

1. Como foi a sua experiência ao utilizar o sistema no dia a dia? Descreva o que chamou mais atenção.

2. Os alertas e classificações apresentados pelo sistema foram claros o suficiente para orientar sua tomada de decisão? Explique. Ex.: você entendeu por que um e-mail foi classificado como phishing?

Seção 2: Impacto

3. Você percebeu alguma mudança na sua rotina de trabalho após o uso do sistema? De que forma?
4. Houve alguma situação em que o sistema não correspondeu às expectativas? Se sim, descreva o que aconteceu.

Seção 3: Sugestões de melhoria

5. O que você melhoraria ou adicionaria ao sistema para torná-lo ainda mais útil no ambiente corporativo? Sinta-se à vontade para compartilhar qualquer ideia ou sugestão.